REVUE DE PRESSE HEBDOMADAIRE

Software Compliance

L'essentiel de la conformité des logiciels embarqués dans les produits de défense

N° 3 – Mardi 20 octobre 2026

Revue de presse hebdomadaire, tous les mardis

Les mises à jour d'Oracle JDK 21 passent sous licence OTN à partir du 20 octobre ; la première norme harmonisée de l'AI Act est citée au Journal officiel ; le CLI d'OVHcloud a été piégé et la campagne GhostAction s'étend ; Trivy, Syft et Grype publient de nouvelles versions.

DANS CE NUMÉRO

SBOM et normes 1
Outils 1
Chaîne d'approvisionnement 2
Commerce international 3
France et UE 3
Licences 3
Glossaire 3
Agenda 4

À LA UNE

Oracle JDK 21 passe sous licence OTN

À partir du correctif trimestriel d'Oracle du 20 octobre 2026, les mises à jour de JDK 21 ne sont plus gratuites en production au-delà des autorisations de la licence OTN.

Oracle JDK 21 : les mises à jour publiées à partir du correctif trimestriel (CPU) d'octobre 2026, daté du 20 octobre, sont prévues sous licence Java SE OTN ; l'usage en production devient payant au-delà des autorisations gratuites de cette licence ; Oracle JDK 25 reste sous licence NFTC jusqu'en septembre 2028.

Jusqu'ici, JDK 21 était gratuit en production et redistribuable sous la licence NFTC (*No-Fee Terms and Conditions*). Il rejoint Java 8, 11 et 17 sous l'OTN, gratuite seulement pour certains usages, dont le développement. Oracle invite les utilisateurs qui veulent garder une licence permissive à passer à JDK 25.

Un équipement qui embarque en production ces nouveaux correctifs de JDK 21 entre dans le champ de la redevance : l'industriel doit recenser ses produits concernés. Un produit maintenu plusieurs années pourrait devoir migrer vers JDK 25 ou vers une distribution OpenJDK, au prix d'une nouvelle qualification du logiciel.

Oracle publie ses correctifs le troisième mardi de janvier, d'avril, de juillet et d'octobre ; la sortie de JDK 25, en septembre 2025, avait ouvert un an de chevauchement pour migrer.

EN BREF

Java 8, 11 et 17 : les versions d'Oracle JDK sont déjà proposées sous licence OTN, gratuite pour les seuls usages personnels, de développement et assimilés.

OpenJDK : Oracle publie aussi sur jdk.java.net des versions de production sous licence GPLv2 avec exception *Classpath*, aujourd'hui JDK 27.

SBOM, NORMES ET RÉFÉRENTIELS

La première norme harmonisée de l'AI Act est citée au Journal officiel ; CycloneDX 2.0 et les normes du CRA restent attendus.

AI Act : l'EN 18286, première norme harmonisée citée au Journal officiel

AI Act, première norme harmonisée : la Commission a annoncé le 19 octobre 2026 la publication au JO de la référence de l'EN 18286:2026 (système de management de la qualité), par la décision d'exécution (UE) 2026/2274 ; elle donne une présomption de conformité à l'article 17.

Élaborée par le CEN et le CENELEC, la norme suit tout le cycle de vie du système d'IA ; elle se superpose à ISO/IEC 42001 ou à ISO 9001 sans les remplacer.

Un fournisseur de système d'IA à haut risque peut désormais s'appuyer sur elle pour son système de management de la qualité, en complément d'une certification ISO 9001. Pour un produit à double usage qui intègre de l'IA, hors de l'exclusion défense, elle pourrait devenir une référence attendue par les clients civils.

EN BREF

CycloneDX 2.0 : version attendue à l'automne 2026, ratification par Ecma en décembre ; le format s'étendrait aux modèles de menaces et à la provenance des composants physiques.

OUTILS ET SERVICES DE CONFORMITÉ

Trivy, Syft et Grype publient de nouvelles versions ; le cadre d'évaluation Privateer entre dans le bac à sable de l'OpenSSF.

Trivy 0.76 : nouvelles sources de correctifs et CBOM enrichi

Trivy 0.76 : le scanneur d'Aqua Security détecte désormais les vulnérabilités des paquets Maven et npm corrigés par Echo, analyse les images RapidFort fondées sur Debian, Oracle Linux, Rocky Linux, AlmaLinux et Amazon Linux, et indique le niveau de sécurité nominal des algorithmes de sa nomenclature cryptographique (CBOM), fonction encore expérimentale.

Publiée le 14 octobre, la version demande normalement une connexion Internet ; sa documentation décrit la configuration d'un réseau restreint ou entièrement isolé.

Les équipes qui comparent des CBOM successifs doivent

prévoir le changement d'identifiant des composants DSA, le format n'offrant aucune compatibilité ascendante garantie. Le niveau de sécurité nominal pourrait aider à repérer la cryptographie faible d'un produit et à documenter les fonctions de chiffrement examinées pour le contrôle des exportations.

En mars, une version de Trivy et des actions GitHub de l'outil avaient distribué un code volant des secrets.

Syft 1.55 et Grype 0.121 : paquets IPK et fin de support des distributions

Syft 1.55 et Grype 0.121 : publiés le 19 octobre 2026 par Anchore, le générateur de SBOM inventorie désormais les paquets IPK, et le scanneur de vulnérabilités tient compte de la date de fin de support publiée par les distributions pour ses alertes de fin de vie.

Syft lit les paquets IPK grâce à son catalogueur d'archives deb ; Grype retrouve aussi les avis GitHub des paquets Swift Package Manager.

Sur un réseau isolé, Grype exige l'import manuel d'une base récente au moins tous les cinq jours avec le réglage par défaut ; Syft fonctionne sans connexion une fois la vérification de mise à jour désactivée. La prise en charge des IPK pourrait étendre l'inventaire aux micrologiciels Linux embarqués qui utilisent ce format. Les alertes de fin de support pourraient signaler plus tôt un système d'exploitation embarqué arrivé en fin de vie. Au lancement, Grype vérifie sa base locale et en cherche une plus récente en ligne.

Privateer : évaluation automatisée de la sécurité et de la conformité

Privateer : l'OpenSSF a annoncé le 13 octobre 2026 l'entrée dans son bac à sable (*Sandbox*) de ce cadre d'évaluation automatisée de la sécurité et de la conformité, à base d'extensions ; les contrôles déterministes passent d'abord, l'IA est facultative, et ses résultats ne déterminent pas la conformité juridique.

Les cas que ces contrôles ne savent pas trancher restent « à revoir ». Selon l'OpenSSF, les résultats peuvent appuyer la préparation au CRA et d'autres démarches d'assurance.

L'outil évalue des dépôts de code sans recourir obligatoirement à l'IA, mais son option d'IA transmet les documents déclarés au fournisseur configuré : pour un code soumis au contrôle des exportations, l'industriel doit vérifier qu'un tel transfert est autorisé. Sans cette option, l'outil pourrait servir à documenter la préparation au CRA de composants open source.

Le billet d'annonce est signé par Jason Meridth et Vinaya Damle.

EN BREF

Plateforme unique du CRA : lancée par l'ENISA le 11 septembre 2026, elle reçoit les déclarations des fabricants.

Chainguard : images durcies livrées avec SBOM signé, mises à jour quotidiennes et délai de 7 jours pour les CVE critiques (promesse de l'éditeur).

SÉCURITÉ DE LA CHAÎNE D'APPROVISIONNEMENT

Le CLI officiel d'OVHcloud a été piégé sur GitHub, la campagne GhostAction s'étend aux postes des développeurs, et GitHub signale les paquets malveillants de huit écosystèmes.

OVHcloud : versions du CLI officiel piégées sur GitHub

OVHcloud CLI : le 19 octobre 2026, pendant environ une heure et demie, les versions v0.11 à v0.15 de l'outil, distribuées depuis son dépôt GitHub officiel, ont embarqué un binaire qui cherchait les secrets sur l'ordinateur ; une vérification de l'empreinte SHA-256 a révélé l'attaque ; la v0.16 est publiée.

Les versions touchées, parues d'avril à septembre, ont été modifiées après coup ; selon Octave Klaba, l'attaquant a utilisé le compte GitHub d'un développeur. La v0.10 n'est pas concernée, et les notes de version ne mentionnent pas l'incident.

Un dépôt officiel peut donc distribuer un logiciel malveillant : une chaîne de construction doit figer l'empreinte des binaires tiers qu'elle télécharge. Sans cette précaution, un composant piégé pourrait entrer dans un produit livré, et des secrets volés sur un poste de développement ouvrir l'accès aux dépôts de l'industriel.

L'attaque a été repérée parce qu'un système d'intégration vérifiait l'empreinte SHA-256 du binaire : l'empreinte ayant changé, l'installation a échoué.

GhostAction : vol d'identifiants par les GitHub Actions, puis par VS Code

GhostAction : selon GitGuardian, cité par The Hacker News, cette campagne de vol d'identifiants vise plus de 30 000 dépôts de 3 000 utilisateurs et organisations, après la compromission d'environ 1 900 comptes GitHub ; une nouvelle étape fait exécuter par VS Code un voleur d'identifiants caché dans une fausse police.

La campagne a tenté d'extraire 3 174 secrets des chaînes d'intégration de dépôts publics ; GitHub bloque le *workflow* malveillant depuis le 9 octobre. Sur 94 dépôts, OpenSourceMalware a aussi relevé une tâche planifiée qui exécute toutes les cinq minutes les commandes de l'attaquant.

Si l'exécution automatique des tâches est autorisée dans VS Code, ouvrir un dépôt piégé suffit à lancer le voleur sur le poste du développeur : ce réglage est à vérifier. Des jetons de publication volés pourraient servir à diffuser des versions piégées de composants open source.

GitHub Actions est le service d'intégration continue de GitHub : un *workflow* malveillant ajouté à un dépôt peut lire les secrets de sa chaîne d'intégration.

GitHub : alertes de paquets malveillants étendues à huit écosystèmes

Paquets malveillants : selon une étude de cas de l'OpenSSF du 16 octobre 2026, GitHub a intégré à sa base d'avis les données du dépôt *Malicious Packages* de l'OpenSSF, plus de 238 000 signalements, et couvre désormais huit écosystèmes, dont npm, PyPI, Maven et crates.io.

Lancé en octobre 2023, ce dépôt public au format OSV alimente désormais la GitHub Advisory Database. Amazon Inspector, ReversingLabs, Checkmarx et Google figurent parmi ses contributeurs.

Les alertes restent facultatives : un dépôt dont les alertes Dependabot sont activées doit les demander pour être prévenu qu'une dépendance figure parmi ces paquets. Publiées au format OSV, ces données pourraient être confrontées aux SBOM des produits pour repérer un composant malveillant dans un logiciel déjà livré.

GitHub avait présenté en août 2026 l'extension de ses alertes au-delà de npm ; plus de 28 000 signalements du dépôt citent GitHub comme source.

EN BREF

Trivy, 19 mars 2026 : la version 0.69.4 et des actions GitHub de l'outil ont distribué un code volant des secrets.

Attaque du 11 mai 2026 : 404 versions malveillantes de paquets npm et PyPI, dont TanStack et Mistral AI.

COMMERCE INTERNATIONAL

Exportations et sanctions

L'UE sanctionne des intermédiaires qui contournent ses mesures contre la Russie ; le Royaume-Uni élargit ses licences générales d'exportation militaires et dual-use.

UE : sanctions contre des intermédiaires qui contournent les mesures visant la Russie

Sanctions, contournement : par le règlement d'exécution (UE) 2026/2333 du 15 octobre 2026, le Conseil inscrit trois personnes et neuf entités, dont des sociétés de commerce impliquées dans l'importation en Russie de biens soumis aux mesures de l'Union.

Le texte met en œuvre le règlement (UE) n° 269/2014. Parmi les inscrits figurent Movers Group LLC, pour l'importation parallèle, et DT Inier LLC, qui propose des solutions d'approvisionnement « clés en main » pour contourner les restrictions. Begler Tekstil Insaat Elektronik ve Dis Ticaret, société de commerce et de logistique, est visée pour la fourniture de produits soumis aux mesures.

Les inscriptions visent des intermédiaires et pas seulement des entreprises russes : le filtrage des distributeurs, transitaires et clients doit intégrer la liste mise à jour. Livrer un logiciel, une licence ou une mise à jour à un intermédiaire inscrit pourrait constituer une violation des mesures de l'Union.

Royaume-Uni : licences générales d'exportation élargies

Royaume-Uni, licences générales : depuis le 14 octobre 2026, l'ECJU étend la licence générale ouverte (OGEL) *dual-use* à douze nouvelles destinations et élargit les deux OGEL des biens, logiciels et technologies militaires, la plus large s'ouvrant notamment à la Pologne, à la Grèce et à la Corée du Sud.

L'OGEL *dual-use* couvre des équipements aéronautiques et maritimes, les technologies de l'information, les semi-conducteurs avancés et le quantique. Parmi les douze nouvelles destinations figurent Bahreïn, le Maroc, Oman, les Philippines et le Qatar.

Une entité britannique peut ainsi exporter vers ces pays sans demande individuelle, si elle respecte les conditions des OGEL ; l'ECJU estime éviter plus de 800 demandes par an. Faute de service de classement, suspendu depuis le 12 octobre, l'exportateur devrait toutefois classer lui-même ses biens.

EN BREF

Sanctions, 22e paquet : adopté le 12 octobre 2026, il inscrit 1 569 personnes et entités, dont des fournisseurs de composants du complexe militaro-industriel russe.

Royaume-Uni, classement : le service CLC de l'ECJU reste suspendu depuis le 12 octobre 2026, sans date de reprise.

CMMC : la suspension de la phase 2, décidée le 13 juillet 2026, reste sans date de reprise ; NIST SP 800-171 et DFARS 252.204-7012 restent applicables.

FRANCE ET UE

NIS2, IA, défense

La loi Résilience n'a pas été réinscrite à l'ordre du jour le 13 octobre ; les dossiers de défense, d'IA et de responsabilité du fait des produits restent ouverts.

Loi Résilience : pas de réinscription le 13 octobre 2026

Mise à jour, loi Résilience : la conférence des présidents de l'Assemblée nationale du 13 octobre 2026 n'a pas réinscrit le projet de loi transposant NIS2, DORA et REC ; la suivante se réunit le 20 octobre.

Le relevé de conclusions porte sur le calendrier de contrôle de la session et ne mentionne pas le texte ; le dossier législatif n'indique aucune date de séance publique.

Les obligations françaises issues de NIS2 restent sans date d'adoption : les entités concernées ne connaissent ni le texte définitif ni son calendrier.

EN BREF

Omnibus défense : le Parlement européen a adopté le 16 septembre 2026 la directive sur les transferts intra-UE de produits de défense, avec de nouvelles licences générales de transfert.

LICENCES OPEN SOURCE ET LOGICIELS EMBARQUÉS

À Moscou, un tribunal refuse de reconnaître des droits propres sur une suite bureautique fondée sur LibreOffice ; le contentieux Vizio et l'enquête sur Bambu Lab restent ouverts.

Russie : une suite fondée sur LibreOffice refusée au registre des logiciels nationaux

Russie, droits sur un logiciel dérivé : le 7 octobre 2026, le tribunal d'arbitrage de Moscou a validé le refus du ministère du Numérique d'inscrire « Free Office », de BaseALT, au registre des logiciels russes ; l'éditeur ne détenait pas les droits sur LibreOffice, composant central.

Pour le tribunal, la localisation russe, les dictionnaires et l'intégration de la signature électronique ne suffisaient pas à fonder une propriété indépendante.

La décision ne vaut qu'en Russie et peut faire l'objet d'un appel. Une déclaration d'origine ou de propriété d'un logiciel, demandée par un client ou par un programme de production nationale, pourrait être contestée si le produit repose surtout sur des composants open source.

EN BREF

GPL, SFC contre Vizio : le procès est indiqué par la SFC pour fin 2026 ; aucun verdict n'a été relevé dans les sources consultées.

AGPLv3 : la SFC a publié le 18 mai 2026 sa réponse aux violations de l'AGPLv3 par Bambu Lab ; l'enquête est en cours.

GLOSSAIRE

Sigles et termes cités

AI Act Règlement européen 2024/1689, premier cadre juridique complet sur l'intelligence artificielle, fondé sur les niveaux de risque.

Anchore Éditeur d'une plateforme de sécurité de la chaîne logicielle fondée sur les SBOM : vulnérabilités, gestion des SBOM, conformité.

CBOM Cryptographic Bill of Materials : inventaire des fonctions cryptographiques (algorithmes, clés, protocoles) d'un matériel ou d'un logiciel.

Chainguard Éditeur d'images de conteneurs et de bibliothèques open source sans vulnérabilité connue, conçus pour la sécurité de la chaîne d'approvisionnement.

CLC Control List Classification : service de l'ECJU indiquant si un bien figure sur les listes britanniques de contrôle des exportations ; suspendu depuis le 12 octobre 2026.

CLI Command-Line Interface : outil qui s'utilise en ligne de commande.

CMMC Cybersecurity Maturity Model Certification : programme du département américain de la Défense qui impose des niveaux de cybersécurité vérifiés à ses fournisseurs.

CPU Critical Patch Update : correctif trimestriel d'Oracle, publié le troisième mardi de janvier, avril, juillet et octobre.

CRA Cyber Resilience Act. Règlement européen 2024/2847 imposant des exigences de cybersécurité aux produits comportant des éléments numériques, avec déclaration des vulnérabilités exploitées depuis le 11 septembre 2026.

CVE Common Vulnerabilities and Exposures : programme qui attribue un identifiant unique à chaque vulnérabilité publiquement connue.

CycloneDX Standard de nomenclature des composants (BOM) pour la chaîne d'approvisionnement, normalisé par Ecma sous la référence ECMA-424.

Dependabot Outil de GitHub qui propose automatiquement des mises à jour de dépendances et alerte sur les vulnérabilités.

DFARS 252.204-7012 Clause du règlement d'acquisition de la Défense américaine imposant la protection des informations non classifiées et la déclaration des incidents cyber.

Directive (UE) 2024/2853 Directive sur la responsabilité du fait des produits défectueux ; remplace la directive 85/374/CEE et inclut le logiciel.

DORA Digital Operational Resilience Act : règlement (UE) 2022/2554 sur la résilience opérationnelle numérique des entités financières.

ECJU Export Control Joint Unit : unité britannique de contrôle des exportations ; elle instruit les licences et publie les avis aux exportateurs.

EDIP European Defence Industry Programme : programme européen de subventions pour renforcer et moderniser l'industrie de défense, avec règle de composants européens.

EN Norme européenne. Norme adoptée par un organisme européen de normalisation (CEN, CENELEC ou ETSI) ; une norme harmonisée citée au JO donne présomption de conformité.

ENISA Agence de l'Union européenne pour la cybersécurité. Elle exploite la plateforme unique de déclaration prévue par le CRA.

ETSI Institut européen des normes de télécommunications : organisme européen de normalisation, chargé avec le CEN et le CENELEC des normes harmonisées du CRA.

GitHub Plateforme collaborative de développement logiciel : gestion de versions, sécurité et déploiement intégrés.

GPL GNU General Public License : licence libre copyleft qui impose de fournir le code source des œuvres dérivées distribuées.

Grype Scanneur open source de vulnérabilités pour images de conteneurs et systèmes de fichiers, souvent utilisé avec des SBOM.

Honeywell Industriel américain de l'aérospatiale, de l'automatisation et des technologies de défense.

IPK Format de paquet logiciel utilisé notamment par des distributions Linux embarquées.

ISO/IEC Organisation internationale de normalisation et Commission électrotechnique internationale, qui publient conjointement les normes des technologies de l'information.

ITAR International Traffic in Arms Regulations : réglementation américaine contrôlant l'exportation et la réexportation de matériels de défense, de données techniques et de logiciels associés.

Java SE Java Platform, Standard Edition : plateforme Java standard, mise en œuvre par le JDK.

JDK Java Development Kit : environnement de développement et d'exécution Java, distribué par Oracle (Oracle JDK) et en open source (OpenJDK).

JO Journal officiel de l'UE. Publication officielle des actes de l'Union européenne ; leur entrée en vigueur dépend de cette publication.

Mistral AI Entreprise française d'intelligence artificielle qui publie des SDK sur npm et PyPI.

NFTC Oracle No-Fee Terms and Conditions : licence d'Oracle permettant l'usage gratuit en production et la redistribution d'Oracle JDK pendant une période limitée.

NIS2 Directive européenne fixant des exigences unifiées de cybersécurité et de notification d'incidents pour les entités essentielles et importantes de nombreux secteurs.

NIST Institut national américain des normes et de la technologie ; il publie notamment les normes FIPS et gère la base NVD.

NIST SP 800-171 Publication du NIST qui fixe les exigences de sécurité pour protéger les informations non classifiées contrôlées chez les fournisseurs du gouvernement américain.

npm Gestionnaire de paquets de Node.js et registre où se publient les modules JavaScript.

OGEL Open General Export Licence : licence générale d'exportation britannique, utilisable sans demande individuelle par l'exportateur qui en respecte les conditions.

OpenSSF Communauté de développeurs et d'ingénieurs sécurité qui travaillent à sécuriser les logiciels open source.

OSV Open Source Vulnerabilities : base de données et format ouverts recensant les vulnérabilités des paquets open source.

OTAN Organisation du traité de l'Atlantique Nord

OTN Oracle Technology Network License Agreement for Java SE : licence d'Oracle gratuite pour des usages limités (personnel, développement) ; l'usage en production au-delà exige une redevance.

PyPI Python Package Index : dépôt officiel où l'on trouve, installe et partage les paquets du langage Python.

REC Directive sur la résilience des entités critiques

SAFE Security Action for Europe : instrument européen de prêts aux États membres pour l'achat de produits de défense, assorti de règles sur l'origine des composants.

SBOM Software Bill of Materials : inventaire structuré des composants d'un logiciel, utilisé pour suivre licences et vulnérabilités.

SFC Software Freedom Conservancy. Organisation à but non lucratif qui héberge des projets de logiciels libres et défend les droits liés à la liberté logicielle.

SHA-256 Fonction de hachage cryptographique qui calcule l'empreinte d'un fichier ; toute modification du fichier change l'empreinte.

TanStack Ensemble de bibliothèques JavaScript open source

Vizio Fabricant américain de téléviseurs connectés

VS Code Visual Studio Code : éditeur de code de Microsoft, très répandu chez les développeurs.

AGENDA Dates à surveiller

20 OCT. — NIS2, DORA
La conférence du 13 octobre n'a pas réinscrit le texte ; aucune date de séance publique n'est fixée

25 OCT. — SANCTIONS
Fin du délai du 21e paquet pour exécuter certains contrats antérieurs

10 NOV. — EXPORT ÉTATS-UNIS
Réimposition automatique de la règle des affiliés du BIS, sauf prolongation

NOV. 2026 — EXPORT UE
Règlement délégué adopté le 14 septembre 2026 ; publication au JO après deux mois d'examen du Parlement européen et du Conseil, sauf objection

9 DÉC. — RESPONSABILITÉ PRODUIT
Transposition de la directive (UE) 2024/2853, qui inclut le logiciel ; elle s'applique aux produits mis sur le marché à partir de cette date

11 DÉC. — CRA
Nombre suffisant d'organismes d'évaluation de la conformité attendu dans les États membres (CRA)

DÉC. 2027 — AI ACT
Règles sur les systèmes d'IA à haut risque de l'annexe III, reportées à cette date par le règlement (UE) 2026/1744

DÉC. 2027 — CRA
Application complète du CRA ; selon l'ENISA, les gestionnaires de logiciels open source sont soumis à la déclaration à la même date

Software Compliance
Revue de presse hebdomadaire, N° 3 du 20 octobre 2026.
Rédigée par une intelligence artificielle (Claude Opus 5.5), sans garantie d'exactitude : pensez à croiser vos sources.
Édition en ligne avec sources : https://revue.dejeun.es/2026-10-20/
© 2026 Rodolphe Dejeunes, publié sous licence CC BY 4.0.